



ÉCOLE POLYTECHNIQUE DE SOUSSE

TP4

IAM avec FreeIPA

Gestion des Identités, Authentification SSH et Protection Fail2ban

Élève :
Hichri SAFA

Enseignante :
Cherif MARIEM

- Année Universitaire 2025-2026

Table des matières

1	TP4	5
1.1	Introduction générale	5
1.2	Architecture de l'environnement	5
1.3	Exercice 1 : Configuration du Serveur et Installation FreeIPA	5
1.3.1	Introduction	5
1.3.2	Mise à jour du système Rocky Linux	6
1.3.3	Configuration de l'adresse IP statique	6
1.3.4	Configuration du FQDN	6
1.3.5	Configuration IP de Kali Linux	6
1.3.6	Installation de FreeIPA Server	7
1.3.7	Provisionnement de FreeIPA	7
1.3.8	Ouverture des ports Firewall	8
1.3.9	Vérification des services et ticket Kerberos	9
1.3.10	Réponses aux questions	10
1.3.11	Conclusion	10
1.4	Exercice 2 :Administration Graphique FreeIPA – Web UI	11
1.4.1	Introduction	11
1.4.2	Création des groupes d'utilisateurs	11
1.4.3	Création des comptes utilisateurs	11
1.4.4	Configuration de la règle HBAC	12
1.4.5	Règle Sudo et politique de mot de passe	13
1.4.6	Réponses aux questions	13
1.4.7	Conclusion	13
1.5	Exercice 3 : Installation et Configuration de Fail2ban	15
1.5.1	Introduction	15
1.5.2	Installation et Configuration de Fail2ban	15
1.5.3	Installation de Fail2ban	15
1.5.4	Configuration de la jail SSH	16
1.5.5	Validation de Fail2ban	17
1.5.6	Réponses aux questions	18
1.5.7	Conclusion	18
1.6	Exercice 4 :Simulation d'Attaque et Analyse des Logs	19
1.6.1	Introduction	19
1.6.2	Simulation d'attaque par force brute (Hydra)	19
1.6.3	Vérification du bannissement	19
1.6.4	Analyse des logs de sécurité	20
1.6.5	Connexion PuTTY depuis Windows (utilisateur bob)	20
1.6.6	Analyse des logs de sécurité	21

1.6.7 Conclusion 21

Table des figures

1.1	Sortie de ip a montrant l'adresse 192.168.100.10	6
1.2	Sortie de hostnamectl montrant ipa.lab.local	7
1.3	Test de ping réussi depuis Kali vers Rocky	8
1.4	Dernières lignes du provisionnement FreeIPA – Setup complete	8
1.5	Sortie de sudo ipactl status – tous les services RUNNING	9
1.6	Sortie de klist – ticket Kerberos	10
1.7	Sortie de ipa group-show developers montrant alice et charlie	11
1.8	liste des utilisateurs créés	12
1.9	Règle HBAC dans l'interface Web UI	12
1.10	Sortie de ipa hbactest	12
1.11	Service Fail2ban en état active (running)	16
1.12	Sortie de sudo fail2ban-client status sshd	17
1.13	Hydra bloqué – Connection refused	19
1.14	192.168.100.20 dans la liste des bannis	20
1.15	tentatives échouées depuis 192.168.100.20	20
1.16	Connexion PuTTY réussie avec bob	21
1.17	Extrait de /var/log/auth.log montrant les tentatives échouées et la fiche alice dans FreeIPA Web UI avec les Failed Login Attempts	21

Liste des tableaux

1.1	Machines virtuelles utilisées	5
1.2	Groupes et membres	11
1.3	Utilisateurs et rôles	12
1.4	Configuration Sudo	13
1.5	Politique globale des mots de passe	13
1.6	Section [DEFAULT] — Paramètres globaux Fail2ban	16
1.7	Section [DEFAULT] — Paramètres globaux Fail2ban	17

Chapitre 1

TP4

1.1 Introduction générale

À l'heure où les cybermenaces se multiplient et se sophistiquent, la gestion centralisée des identités et des accès (IAM – Identity and Access Management) est devenue un pilier fondamental de la sécurité des systèmes d'information. Ce Lab 4 nous plonge dans la réalité d'un déploiement IAM complet au sein d'une startup fictive tunisienne, SecureCorpTN.

Nous incarnons successivement deux rôles : celui d'administrateur IAM responsable de déployer et sécuriser l'infrastructure, et celui d'attaquant éthique chargé de valider la robustesse des mécanismes de protection mis en place.

1.2 Architecture de l'environnement

VM	Nom	Système	Rôle
VM1	IPA_Safa	Rocky Linux 10.1	Serveur FreeIPA
VM2	KALI_Safa	Kali Linux	Machine d'attaque

TABLE 1.1 – Machines virtuelles utilisées

Ce TP a été réalisé sur Rocky Linux 10.1 au lieu d'Ubuntu 22.04 (énoncé original). Toutes les commandes et configurations ont été adaptées en conséquence. Les différences clés sont signalées tout au long du rapport.

1.3 Exercice 1 : Configuration du Serveur et Installation FreeIPA

1.3.1 Introduction

Avant de déployer un système d'authentification centralisée, toute infrastructure doit reposer sur des fondations réseau solides. Cette partie constitue le socle technique du lab : vous allez préparer les deux machines virtuelles, configurer leurs adresses IP statiques, définir les noms d'hôtes, puis procéder à l'installation et au provisionnement complet de FreeIPA Server. FreeIPA est une solution IAM (Identity and Access Management) open source qui intègre en un seul déploiement Kerberos, LDAP, DNS et une PKI. Sans une configuration réseau et un FQDN corrects, l'installation est vouée à l'échec, c'est pourquoi chaque étape doit être réalisée avec rigueur avant de passer à la suite.

1.3.2 Mise à jour du système Rocky Linux

Avant toute installation, le système a été mis à jour pour garantir la cohérence des paquets :

```
# Mise a jour complete du systeme
sudo dnf update -y
# Installation des prerequis de base
sudo dnf install -y curl wget
```

Sur Rocky Linux, le gestionnaire de paquets est dnf (et non apt comme sur Ubuntu). Les dépôts sont ceux de Rocky Linux, compatibles Red Hat Enterprise Linux.

1.3.3 Configuration de l'adresse IP statique

Rocky Linux utilise NetworkManager (nmcli) pour la gestion réseau, contrairement à Ubuntu qui utilise Netplan. La VM dispose de deux interfaces réseau :

- ens160 : Interface NAT – accès Internet (IP DHCP : 192.168.143.138)
- ens192 : Interface Host-Only – communication inter-VMs (IP fixe : 192.168.100.10)

```
3: ens192: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group de
fault qlen 1000
    link/ether 00:0c:29:02:5d:02 brd ff:ff:ff:ff:ff:ff
    altname enp11s0
    altname enx000c29025d02
    inet 192.168.100.10/24 brd 192.168.100.255 scope global noprefixroute ens192
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe02:5d02/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
safa@ipa:~$
```

FIGURE 1.1 – Sortie de ip a montrant l'adresse 192.168.100.10

1.3.4 Configuration du FQDN

Le FQDN (Fully Qualified Domain Name) est critique pour FreeIPA. Kerberos, LDAP et DNS l'utilisent pour identifier le serveur. Une erreur ici est la cause numéro 1 des échecs d'installation.

1.3.5 Configuration IP de Kali Linux

Sur la VM Kali Linux, l'IP statique a été configurée dans `/etc/network/interfaces` :

```
Les deux VMs se pinguent mutuellement sans perte de paquets. Kali → Rocky :
ping 192.168.100.10 → 0% packet loss Rocky → Kali : ping 192.168.100.20 → 0%
packet loss
```

```
safa@ipa:~$ hostnamectl
  Static hostname: ipa.lab.local
        Icon name: computer-vm
        Chassis: vm 🖥️
        Machine ID: 1d09e76c74504d5684332d778a598bc2
        Boot ID: a5641cbbb1844429a7189660fe216efd
        AF_VSOCK CID: 1224891896
        Virtualization: vmware
        Operating System: Rocky Linux 10.1 (Red Quartz)
        CPE OS Name: cpe:/o:rocky:rocky:10::baseos
        OS Support End: Thu 2035-05-31
        OS Support Remaining: 9y 1month 3w 3d
        Kernel: Linux 6.12.0-124.8.1.el10_1.x86_64
        Architecture: x86-64
        Hardware Vendor: VMware, Inc.
        Hardware Model: VMware Virtual Platform
        Firmware Version: 6.00
        Firmware Date: Thu 2020-11-12
        Firmware Age: 5y 4month 3w 1d
```

FIGURE 1.2 – Sortie de hostnamectl montrant ipa.lab.local

1.3.6 Installation de FreeIPA Server

Sur Rocky Linux, FreeIPA est disponible nativement dans les dépôts officiels

```
# Installation FreeIPA + module DNS
sudo dnf install -y freeipa-server freeipa-server-dns
```

L'installation installe automatiquement : MIT Kerberos, 389 Directory Server (LDAP), Dogtag PKI, BIND9 (DNS), NTP/Chrony, Apache HTTPD et l'interface web FreeIPA.

1.3.7 Provisionnement de FreeIPA

Le provisionnement de FreeIPA a été réalisé à l'aide de l'assistant d'installation.

Lors de l'exécution, plusieurs paramètres ont été configurés. Le nom du serveur a été défini comme **ipa.lab.local**, tandis que le domaine utilisé est **lab.local** et le realm associé est **LAB.LOCAL**.

Les mots de passe du Directory Manager et de l'administrateur IPA ont été configurés avec la même valeur sécurisée. La configuration du service DNS a été activée, avec l'utilisation du serveur de transfert **8.8.8.8**. L'option de recherche des zones inverses manquantes a été désactivée, tandis que la création d'une zone inverse a été acceptée. Enfin, la configuration a été validée et l'installation s'est poursuivie avec succès.

```
(kali㉿kali)-[~]  
$ ping 192.168.100.10  
PING 192.168.100.10 (192.168.100.10) 56(84) bytes of data.  
64 bytes from 192.168.100.10: icmp_seq=1 ttl=64 time=2.44 ms  
64 bytes from 192.168.100.10: icmp_seq=2 ttl=64 time=0.874 ms  
64 bytes from 192.168.100.10: icmp_seq=3 ttl=64 time=0.988 ms  
64 bytes from 192.168.100.10: icmp_seq=4 ttl=64 time=1.22 ms  
64 bytes from 192.168.100.10: icmp_seq=5 ttl=64 time=1.14 ms  
^C  
— 192.168.100.10 ping statistics —  
5 packets transmitted, 5 received, 0% packet loss, time 4006ms  
rtt min/avg/max/mdev = 0.874/1.330/2.435/0.564 ms
```

FIGURE 1.3 – Test de ping réussi depuis Kali vers Rocky

```
Setup complete  
  
Next steps:  
  1. You must make sure these network ports are open:  
     TCP Ports:  
       * 80, 443: HTTP/HTTPS  
       * 389, 636: LDAP/LDAPS  
       * 88, 464: kerberos  
       * 53: bind  
     UDP Ports:  
       * 88, 464: kerberos  
       * 53: bind  
       * 123: ntp  
  
The ipa-server-install command was successful  
=====
```

```
safa@ipa:~$ █
```

FIGURE 1.4 – Dernières lignes du provisionnement FreeIPA – Setup complete

1.3.8 Ouverture des ports Firewall

Sur Rocky Linux, le pare-feu est g  r   par firewalld (non ufw) Il sert    autoriser ou bloquer les connexions r  seau.

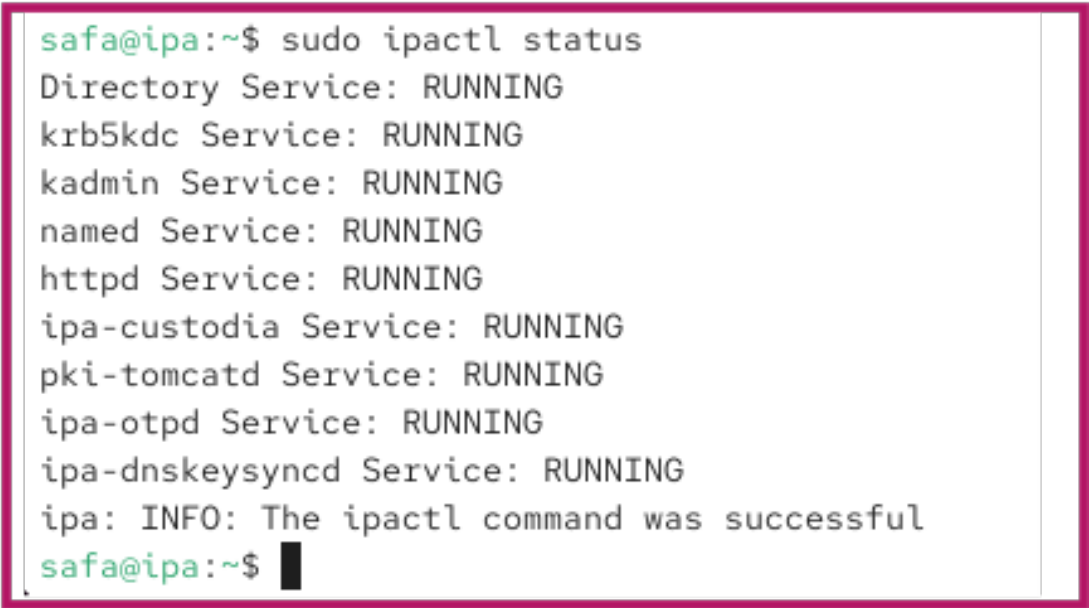
Par d  faut, il bloque presque tout    donc FreeIPA ne fonctionne pas si on n'ouvre pas les bons ports.

```
sudo firewall-cmd --permanent --add-service=freeipa-ldap
sudo firewall-cmd --permanent --add-service=freeipa-ldaps
sudo firewall-cmd --permanent --add-service=dns
sudo firewall-cmd --permanent --add-service=ntp
sudo firewall-cmd --permanent --add-service=ssh
sudo firewall-cmd --permanent --add-service=http
sudo firewall-cmd --permanent --add-service=https
sudo firewall-cmd --permanent --add-service=kerberos
sudo firewall-cmd --permanent --add-service=kpasswd
sudo firewall-cmd --reload
```

freeipa-ldap → (port 389) : communication LDAP (annuaire des utilisateurs)
freeipa-ldaps → (port 636) : LDAP sécurisé (chiffré)
dns → (port 53) : résolution des noms (ex : ipa.lab.local)
ntp → (port 123) : synchronisation de l'heure (TRÈS important pour Kerberos)
ssh → (port 22) : accès à distance à la machine
http → (port 80) : accès web (interface FreeIPA)
https → (port 443) : accès web sécurisé
kerberos → (port 88) : authentification (login sécurisé)
kpasswd → (port 464) : changement de mot de passe Kerberos

1.3.9 Vérification des services et ticket Kerberos

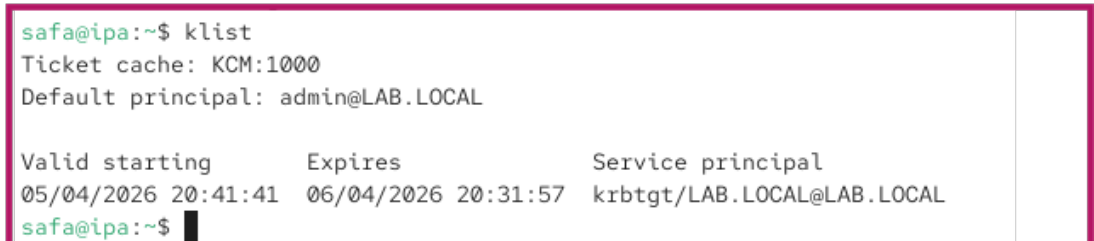
```
# Vérifier que tous les services sont actifs
sudo ipactl status
```



```
safa@ipa:~$ sudo ipactl status
Directory Service: RUNNING
krb5kdc Service: RUNNING
kadmin Service: RUNNING
named Service: RUNNING
httpd Service: RUNNING
ipa-custodia Service: RUNNING
pki-tomcatd Service: RUNNING
ipa-otpd Service: RUNNING
ipa-dnskeysyncd Service: RUNNING
ipa: INFO: The ipactl command was successful
safa@ipa:~$
```

FIGURE 1.5 – Sortie de `sudo ipactl status` – tous les services RUNNING

```
# Obtenir le ticket TGT administrateur
kinit admin
klist
```



```
safa@ipa:~$ klist
Ticket cache: KCM:1000
Default principal: admin@LAB.LOCAL

Valid starting    Expires          Service principal
05/04/2026 20:41:41 06/04/2026 20:31:57 krbtgt/LAB.LOCAL@LAB.LOCAL
safa@ipa:~$
```

FIGURE 1.6 – Sortie de klist – ticket Kerberos

1.3.10 Réponses aux questions

Pourquoi FreeIPA nécessite-t-il que le temps soit synchronisé entre tous les nœuds ? Quel composant s'en charge ? Quel composant de FreeIPA rend le DNS indispensable à son fonctionnement ?

Synchronisation du temps : Kerberos impose une tolérance maximale de 5 minutes (clock skew) entre les machines. Au-delà, les tickets sont rejetés comme invalides, car Kerberos utilise des timestamps pour prévenir les attaques par rejeu (replay attacks). Le composant NTP (géré par Chrony dans FreeIPA) assure cette synchronisation.

DNS indispensable : Kerberos identifie les services par leur nom FQDN (ex : host/ipa.lab.local@LAB.LOCAL) et non par IP. Sans DNS, les principaux Kerberos ne peuvent pas être résolus, rendant l'authentification impossible. BIND9 intégré à FreeIPA fournit cette résolution dans le domaine lab.local.

1.3.11 Conclusion

À l'issue de cette partie, mon serveur FreeIPA est pleinement opérationnel : l'IP statique est configurée, le FQDN est correctement défini, et tous les services critiques — Kerberos, LDAP, DNS, HTTP — sont en état RUNNING. L'obtention d'un ticket TGT via kinit admin confirme que le mécanisme SSO de Kerberos fonctionne correctement. Cette infrastructure constitue désormais la base sur laquelle reposera toute la gestion centralisée des identités de SecureCorpTN.

1.4 Exercice 2 :Administration Graphique FreeIPA – Web UI

1.4.1 Introduction

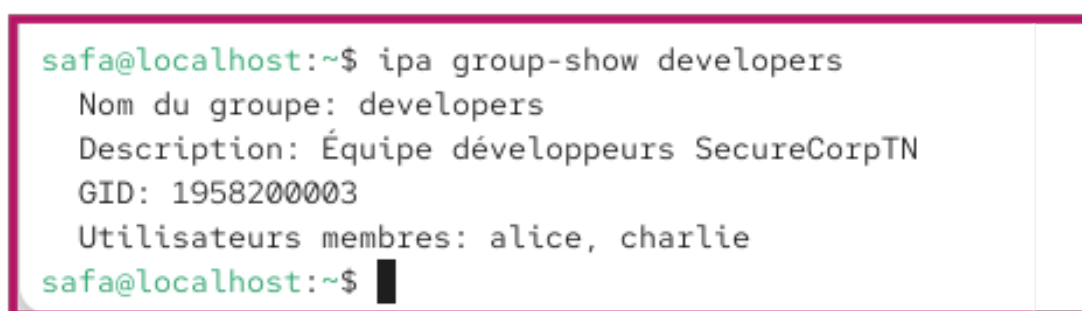
Un serveur FreeIPA fraîchement installé est vide de tout contenu métier. L’administrateur IAM doit le peupler avec la structure organisationnelle réelle de l’entreprise : utilisateurs, groupes, règles d’accès et politiques de sécurité. Dans cette partie, vous incarnez l’administrateur IAM de SecureCorpTN et vous allez exploiter l’interface web de FreeIPA pour créer une structure complète reflétant deux départements — Développement et Réseau/Admin. Vous configurerez également des mécanismes de contrôle d’accès avancés : les règles HBAC pour restreindre les connexions SSH, les règles Sudo pour déléguer des privilèges d’administration, et une politique de mot de passe conforme aux bonnes pratiques de sécurité.

1.4.2 Création des groupes d’utilisateurs

Deux groupes ont été créés dans Identity → Groups → User Groups pour structurer l’organisation SecureCorpTN :

Groupe	Description	Membres
developers	Équipe développeurs SecureCorpTN	alice, charlie
netadmins	Administrateurs réseau SecureCorpTN	bob

TABLE 1.2 – Groupes et membres



```
safa@localhost:~$ ipa group-show developers
Nom du groupe: developers
Description: Équipe développeurs SecureCorpTN
GID: 1958200003
Utilisateurs membres: alice, charlie
safa@localhost:~$
```

FIGURE 1.7 – Sortie de ipa group-show developers montrant alice et charlie

1.4.3 Création des comptes utilisateurs

Trois comptes ont été créés dans Identity → Users → Active users :

Alice et charlie apparaissent dans le groupe developers. bob apparaît dans le groupe netadmins.

Login	Nom complet	Groupe	Titre de poste
alice	Alice Dupont	developers	Développeuse Full-Stack
bob	Bob Martin	netadmins	Administrateur Réseau
charlie	Charlie Ben Ali	developers	Développeur

TABLE 1.3 – Utilisateurs et rôles

Utilisateurs actifs

Rechercher

Rafraîchir Supprimer Ajouter Désactiver Activer Actions

	Identifiant de connexion	Prénom	Nom	État	UID	Adresse courriel	Numéro de téléphone	Titre de poste
☐	admin		Administrateur	✓ Activé(e)	1958200000			
☐	alice	Alice	Dupont	✓ Activé(e)	1958200005	alice@lab.local		Développeuse Full-Stack
☐	bob	Bob	Martin	✓ Activé(e)	1958200006	bob@lab.local		Administrateur Réseau
☐	charlie	Charlie	Ben Ali	✓ Activé(e)	1958200007	charlie@lab.local		

Affichage des entrées 1 à 4 sur 4.

FIGURE 1.8 – liste des utilisateurs créés

1.4.4 Configuration de la règle HBAC

HBAC (Host-Based Access Control) définit qui peut accéder à quel service sur quel hôte. La règle allow_ssh_developers a été configurée dans Policy → Host-Based Access Control → HBAC

```
# Test de la règle HBAC
ipa hbactest -user=alice -host=ipa.lab.local -service=sshd
```

Règles HBAC

Rechercher

	Nom de règle	État	Description
☐	allow_all	✓ Activé(e)	Allow all users to access any host from any host
☐	allow_ssh_developers	✓ Activé(e)	
☐	allow_systemd-user	✓ Activé(e)	Allow pam_systemd to run user@.service to create a system user session

Affichage des entrées 1 à 3 sur 3.

FIGURE 1.9 – Règle HBAC dans l’interface Web UI

```
safa@localhost:~$ ipa hbactest --user=alice --host=ipa.lab.local --service=sshd
-----
Accès autorisé : True
-----
Règles satisfaites: allow_all
Règles satisfaites: allow_ssh_developers
Règles non satisfaites: allow_systemd-user
```

FIGURE 1.10 – Sortie de ipa hbactest

1.4.5 Règle Sudo et politique de mot de passe

Règle Sudo pour les netadmins (Policy → Sudo → Sudo Rules) :

Paramètre Sudo	Valeur
Nom	netadmins_sudo
Qui	Groupe : netadmins
Commandes	Toutes les commandes (All Commands)
Exécuté en tant que	root

TABLE 1.4 – Configuration Sudo

Politique de mot de passe (Policy → Password Policies → global_policy) :

Paramètre	Valeur
Durée maximale	90 jours
Durée minimale	1 heure
Historique	10 anciens mots de passe
Longueur minimale	8 caractères
Classes de caractères	3 minimum (majuscules, chiffres, symboles)

TABLE 1.5 – Politique globale des mots de passe

1.4.6 Réponses aux questions

Quelle est la différence fondamentale entre une règle HBAC et une règle Sudo dans FreeIPA ? Donnez un exemple concret d’usage de chacune dans un contexte d’entreprise

HBAC (Host-Based Access Control) contrôle QUI peut SE CONNECTER à quel service sur quel hôte. Elle agit au niveau de l’accès réseau, AVANT que l’utilisateur soit authentifié sur la machine. Exemple entreprise : Seuls les membres du groupe developers peuvent se connecter en SSH au serveur de production. Les RH ou la comptabilité en sont exclus.

Règle Sudo contrôle ce qu’un utilisateur DÉJÀ CONNECTÉ peut faire avec des privilèges élevés. Elle agit APRÈS la connexion. Exemple entreprise : Les membres de netadmins peuvent exécuter toutes les commandes en root sur les serveurs réseau, tandis que les developers ne peuvent exécuter que sudo systemctl restart apache2. En résumé : HBAC = contrôle de l’accès (qui entre), Sudo = contrôle des privilèges (ce qu’on fait une fois entré).

1.4.7 Conclusion

SecureCorpTN dispose maintenant d’un annuaire structuré et opérationnel. Les utilisateurs alice, bob et charlie sont créés, affectés à leurs groupes respectifs, et soumis à des règles d’accès précises. La règle HBAC allow_ssh_developers garantit que seuls les membres autorisés peuvent établir des connexions SSH, tandis que la règle Sudo netadmins_sudo délègue les privilèges d’administration au groupe réseau de manière contrôlée.

Ces mécanismes illustrent concrètement le principe du moindre privilège, pierre angulaire de toute politique de sécurité en entreprise.

1.5 Exercice 3 : Installation et Configuration de Fail2ban

1.5.1 Introduction

Un serveur exposé sur le réseau, même protégé par FreeIPA, reste vulnérable aux attaques par force brute sur le port SSH. Un attaquant peut tenter des milliers de combinaisons de mots de passe de manière automatisée, sans que le système d'authentification seul ne l'en empêche. Fail2ban répond à cette menace en analysant en temps réel les journaux système et en bannissant automatiquement les adresses IP qui dépassent un seuil de tentatives échouées. Cette partie nous guide dans l'installation, la configuration et la validation de Fail2ban pour protéger le service SSH du serveur FreeIPA, en appliquant les bonnes pratiques de configuration (fichier local de surcharge, paramétrage adapté au contexte de test).

1.5.2 Installation et Configuration de Fail2ban

Le serveur FreeIPA expose le port SSH 22 sur le réseau local. Sans protection, un attaquant peut tenter des milliers de mots de passe (attaque par force brute). Fail2ban surveille les logs d'authentification et bloque automatiquement les IP malveillantes.

1.5.3 Installation de Fail2ban

Sur Rocky Linux, Fail2ban est disponible via le dépôt EPEL (Extra Packages for Enterprise Linux) :

```
# Activation du dépôt EPEL (obligatoire sur Rocky)
sudo dnf install -y epel-release
# Installation de Fail2ban
sudo dnf install -y fail2ban
# Démarrage et activation au boot
sudo systemctl enable --now fail2ban
sudo systemctl status fail2ban
```

```

safa@localhost:~$ sudo systemctl status fail2ban
● fail2ban.service - Fail2Ban Service
   Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset:
   Active: active (running) since Sun 2026-04-05 11:58:22 CET; 12s ago
   Invocation: 38e6f8956e88496bb35f336ffdeac3fd
     Docs: man:fail2ban(1)
   Process: 26038 ExecStartPre=/bin/mkdir -p /run/fail2ban (code=exited, statu
  Main PID: 26039 (fail2ban-server)
     Tasks: 3 (limit: 22806)
    Memory: 13.5M (peak: 14M)
       CPU: 135ms
    CGroup: /system.slice/fail2ban.service
            └─26039 /usr/bin/python3 -sP /usr/bin/fail2ban-server -xf start

avril 05 11:58:21 ipa.lab.local systemd[1]: Starting fail2ban.service - Fail2Ba
avril 05 11:58:22 ipa.lab.local systemd[1]: Started fail2ban.service - Fail2Ban
avril 05 11:58:22 ipa.lab.local fail2ban-server[26039]: Server ready
lines 1-16/16 (END)

```

FIGURE 1.11 – Service Fail2ban en état active (running)

1.5.4 Configuration de la jail SSH

Pourquoi jail.local et pas jail.conf ?

jail.conf est le fichier de configuration officiel de Fail2ban. Si Fail2ban est mis à jour, ce fichier est écrasé automatiquement et tu perdrais toutes tes modifications. jail.local est un fichier de surcharge : Fail2ban lit d'abord jail.conf puis jail.local, et les paramètres de jail.local prennent priorité. C'est la bonne pratique.

Section [DEFAULT] – Paramètres globaux :

Paramètre	Valeur	Signification
ignoreip	127.0.0.1/8 : :1 192.168.100.1	IPs jamais bannies (localhost + passerelle réseau). Si ton IP est ici, tu ne seras jamais banni même après plusieurs échecs.
bantime	600	Durée du bannissement en secondes (600s = 10 minutes). Après ce délai, l'IP est automatiquement débannie.
findtime	300	Fenêtre d'observation en secondes (5 minutes). Fail2ban compte les échecs uniquement dans cette période.
maxretry	3	Nombre maximum de tentatives échouées avant bannissement.
backend	3	Indique comment Fail2ban lit les logs. Sous Rocky Linux, les logs SSH passent par systemd/journald.

TABLE 1.6 – Section [DEFAULT] — Paramètres globaux Fail2ban

Exemple concret : Si quelqu'un échoue 3 fois en SSH en moins de 5 minutes →

banni 10 minutes.

Section [sshd] – Configuration spécifique SSH :

Paramètre	Valeur	Signification
enabled	True	Active la surveillance SSH
port	ssh	Port surveillé (équivalent à 22)
filter	sshd	Fichier de filtre utilisé : /etc/fail2ban/filter.d/sshd.conf. Contient les expressions régulières qui détectent les échecs SSH dans les logs.
logpath	/var/log/secure	Fichier de logs surveillé. Sur Rocky Linux c'est /var/log/secure. Sur Ubuntu c'est /var/log/auth.log.
maxretry	systemd	Surcharge le paramètre DEFAULT pour SSH spécifiquement

TABLE 1.7 – Section [DEFAULT] — Paramètres globaux Fail2ban

Sur Ubuntu, Fail2ban lit directement le fichier /var/log/auth.log (backend = fichier texte). Sur Rocky Linux, les logs SSH passent d'abord par journald (le système de logs de systemd), donc Fail2ban doit utiliser backend = systemd pour les lire correctement. De plus, Rocky 10 utilise nftables (plus moderne) au lieu d'iptables pour créer les règles de blocage.

1.5.5 Validation de Fail2ban

```
sudo systemctl restart fail2ban
sudo fail2ban-client status
```

```
safa@localhost:~$ sudo fail2ban-client status
Status
|- Number of jail:      1
`- Jail list:  sshd
safa@localhost:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed: 0
|  |- Total failed:     0
|  `-- Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd + _COMM=sshd-session
`- Actions
   |- Currently banned: 0
   |- Total banned:     0
   `-- Banned IP list:
```

FIGURE 1.12 – Sortie de sudo fail2ban-client status sshd

1.5.6 Réponses aux questions

Quelle est la valeur optimale du paramètre bantime en production ? Justifiez. Que se passe-t-il si un administrateur légitime se fait accidentellement bannir ? Comment procéder au débannissement ?

Valeur optimale de bantime en production : Une valeur entre 3600 secondes (1 heure) et 86400 secondes (24 heures) est recommandée. Pour les systèmes critiques, bantime = -1 (permanent) avec révision manuelle est préférable. Dans notre lab, 600 secondes (10 min) était suffisant pour les tests.

Justification : Un bantime trop court (< 10 min) n'est pas dissuasif pour un attaquant organisé. Un bantime trop long peut gêner les administrateurs légitimes.

Si un administrateur légitime est banni accidentellement, deux options :

1. Accès console direct (accès physique ou IPMI) : `sudo fail2ban-client set sshd unbanip <IP>`

2. Attendre l'expiration du bantime

Prévention : Ajouter l'IP de l'administrateur à `ignoreip` dans `jail.local`. Toujours disposer d'un accès out-of-band (console, VPN séparé) comme solution de secours

1.5.7 Conclusion

Fail2ban est désormais actif et surveille en permanence les tentatives d'authentification SSH. La jail sshd est configurée avec des seuils cohérents : 3 tentatives échouées en moins de 5 minutes déclenchent un bannissement de 10 minutes. Les règles iptables générées automatiquement confirment que le mécanisme de blocage est bien en place au niveau réseau. Couplé à FreeIPA, Fail2ban forme une première ligne de défense efficace contre les attaques automatisées, réduisant considérablement la surface d'exposition du serveur.

1.6 Exercice 4 :Simulation d'Attaque et Analyse des Logs

1.6.1 Introduction

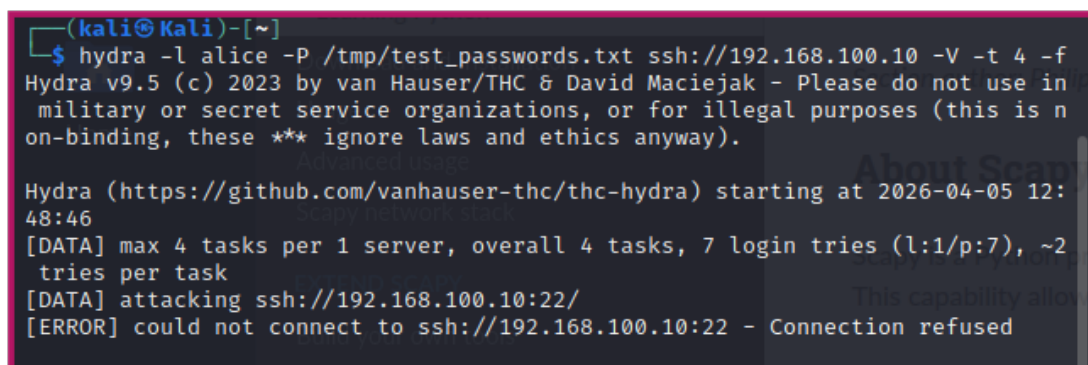
Déployer des mécanismes de sécurité ne suffit pas il faut les tester dans des conditions réalistes pour valider leur efficacité. Cette dernière partie adopte une approche offensive contrôlée : nous allons simuler une attaque par force brute SSH depuis Kali Linux à l'aide d'Hydra, exactement comme le ferait un attaquant réel sur notre infrastructure. L'objectif est double : d'une part, vérifier que Fail2ban détecte et bloque automatiquement l'attaque, d'autre part, apprendre à lire et interpréter les logs de sécurité générés , compétence indispensable pour tout analyste SOC ou administrateur système. La partie se conclut par les procédures d'audit dans FreeIPA et de débannissement d'une IP légitime.

AVERTISSEMENT ÉTHIQUE ET LÉGAL : Cette simulation d'attaque est réalisée UNIQUEMENT dans l'environnement contrôlé du lab, sur nos propres VMs. Reproduire ces actions sur des systèmes tiers sans autorisation écrite explicite est un délit pénal. Ne jamais utiliser ces techniques hors d'un cadre légal et éthique.

1.6.2 Simulation d'attaque par force brute (Hydra)

Avant l'attaque, une connexion légitime valide le bon fonctionnement du serveur , apres Un fichier de mots de passe de test a été créé sur Kali Linux :

Après 3 tentatives échouées, Hydra reçoit : [ERROR] could not connect to ssh ://192.168.100.10 :22 - Connection refused Fail2ban a détecté l'attaque et banni l'IP 192.168.100.20!



```
(kali㉿kali)-[~]
└─$ hydra -l alice -P /tmp/test_passwords.txt ssh://192.168.100.10 -V -t 4 -f
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-05 12:
48:46
[DATA] max 4 tasks per 1 server, overall 4 tasks, 7 login tries (l:1/p:7), ~2
tries per task
[DATA] attacking ssh://192.168.100.10:22/
[ERROR] could not connect to ssh://192.168.100.10:22 - Connection refused
```

FIGURE 1.13 – Hydra bloqué – Connection refused

1.6.3 Vérification du bannissement

La commande `sudo fail2ban-client status sshd` permet de vérifier l'état de protection du service SSH par Fail2Ban. Le résultat montre que plusieurs tentatives de connexion ont échoué (8 au total, dont 1 récente), ce qui indique une activité suspecte comme une attaque par force brute. En réponse, Fail2Ban a automatiquement bloqué une adresse IP (192.168.100.20), actuellement bannie, afin d'empêcher tout nouvel accès non autorisé.

Cela prouve que le mécanisme de sécurité fonctionne correctement en détectant et en bloquant les comportements malveillants.

```
safa@localhost:~$ sudo fail2ban-client status sshd

Status for the jail: sshd
|- Filter
| |- Currently failed: 1
| |- Total failed:      8
| `-- Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd + _COMM=sshd-session
`- Actions
   |- Currently banned: 1
   |- Total banned:      1
   `-- Banned IP list:   192.168.100.20

safa@localhost:~$
```

FIGURE 1.14 – 192.168.100.20 dans la liste des bannis

1.6.4 Analyse des logs de sécurité

L'analyse des logs de sécurité consiste à examiner les tentatives de connexion SSH enregistrées dans le fichier `/var/log/secure` sur Rocky Linux. La commande `grep "Failed password"` permet d'afficher les échecs d'authentification, montrant ici plusieurs tentatives provenant de l'adresse IP 192.168.100.20 visant l'utilisateur alice. Ensuite, la commande avec `awk`, `sort` et `uniq` permet de compter le nombre d'échecs par adresse IP, révélant 7 tentatives pour cette même IP. Enfin, les logs de Fail2Ban (via `journalctl`) confirment que ce comportement a été détecté comme suspect, et que l'adresse IP a été automatiquement bannie après avoir dépassé le seuil autorisé. Cela démontre l'efficacité du système de sécurité dans la détection et la prévention des attaques par force brute.

```
safa@localhost:~$ sudo grep "Failed password" /var/log/secure | tail -20
Apr  5 13:47:30 localhost sshd-session[27465]: Failed password for alice from 192.168.100.20 port 48094 ssh2
Apr  5 13:47:30 localhost sshd-session[27464]: Failed password for alice from 192.168.100.20 port 48084 ssh2
Apr  5 13:47:30 localhost sshd-session[27466]: Failed password for alice from 192.168.100.20 port 48098 ssh2
Apr  5 13:47:30 localhost sshd-session[27468]: Failed password for alice from 192.168.100.20 port 48112 ssh2
Apr  5 13:47:33 localhost sshd-session[27466]: Failed password for alice from 192.168.100.20 port 48098 ssh2
Apr  5 13:47:33 localhost sshd-session[27465]: Failed password for alice from 192.168.100.20 port 48094 ssh2
Apr  5 13:47:33 localhost sshd-session[27464]: Failed password for alice from 192.168.100.20 port 48084 ssh2
Apr  5 13:51:23 localhost sudo[27685]:    safa : TTY=pts/0 ; PWD=/home/safa ; USER=root ; COMMAND=/bin/grep 'Failed pas
safa@localhost:~$
```

FIGURE 1.15 – tentatives échouées depuis 192.168.100.20

1.6.5 Connexion PuTTY depuis Windows (utilisateur bob)

PuTTY (client SSH Windows) a été utilisé pour tester la connexion légitime avec bob

Connexion PuTTY réussie avec bob. La commande `id` confirme l'appartenance au groupe `netadmins`, géré centralement par FreeIPA.

```
-sh-5.2$ whoami
bob
-sh-5.2$ id
uid=1958200006(bob) gid=1958200006(bob) groupes=1958200006(bob),1958200004(netad
mins) contexte=unconfined_u:unconfined_r:unconfined_t:s0-s0:c0.c1023
-sh-5.2$ sudo -l

Nous espérons que vous avez reçu de votre administrateur système local
les consignes traditionnelles. Généralement, elles se concentrent sur ces trois
éléments :

#1) Respectez la vie privée des autres.
#2) Réfléchissez avant d'utiliser le clavier.
#3) De grands pouvoirs confèrent de grandes responsabilités.

Pour des raisons de sécurité, le mot de passe que vous tapez ne sera pas visible
```

FIGURE 1.16 – Connexion PuTTY réussie avec bob

1.6.6 Analyse des logs de sécurité

```
safa@localhost:~$ sudo grep "Failed password" /var/log/secure | tail -20
Apr  5 13:47:30 localhost sshd-session[27465]: Failed password for alice from 192.168.100.20 port 48094 ssh
2
Apr  5 13:47:30 localhost sshd-session[27464]: Failed password for alice from 192.168.100.20 port 48084 ssh
2
Apr  5 13:47:30 localhost sshd-session[27466]: Failed password for alice from 192.168.100.20 port 48098 ssh
2
Apr  5 13:47:30 localhost sshd-session[27468]: Failed password for alice from 192.168.100.20 port 48112 ssh
2
Apr  5 13:47:33 localhost sshd-session[27466]: Failed password for alice from 192.168.100.20 port 48098 ssh
2
Apr  5 13:47:33 localhost sshd-session[27465]: Failed password for alice from 192.168.100.20 port 48094 ssh
2
Apr  5 13:47:33 localhost sshd-session[27464]: Failed password for alice from 192.168.100.20 port 48084 ssh
2
```

FIGURE 1.17 – Extrait de /var/log/auth.log montrant les tentatives échouées et la fiche alice dans FreeIPA Web UI avec les Failed Login Attempts

1.6.7 Conclusion

Ce lab de bout en bout nous a permis de vivre le cycle complet d'une infrastructure IAM sécurisée : déploiement, administration, protection et réponse à incident. L'attaque simulée avec Hydra a été détectée et bloquée en quelques secondes par Fail2ban, l'adresse IP de Kali a été inscrite dans les règles iptables, et les logs auth.log et journald ont conservé la trace complète de l'incident. nous avons également pratiqué le débannissement d'urgence, procédure critique lorsqu'un administrateur légitime se retrouve accidentellement bloqué. L'ensemble de ces compétences, de la configuration Kerberos à l'analyse foren-sique des logs, sont directement transférables dans un environnement professionnel de cybersécurité.

